SECUREAUDIT PRO

Vulnerability Assessment Report

A comprehensive passive security audit of testphp.vulnweb.com, identifying critical weaknesses and providing clear, actionable remediation guidance.

TARGET WEBSITE **testphp.vulnweb.com**	ASSESSMENT DATE **April 2025**
PREPARED BY **SecureAudit Pro**	REPORT VERSION **v1.0 — Initial Release**
ASSESSMENT TYPE ***Passive / Read-Only Audit***	OVERALL GRADE **F — Critical Risk**

RISK SUMMARY

1	3	4	2
CRITICAL	HIGH	MEDIUM	LOW

01 Executive Summary

ASSESSMENT CONCLUSION

This website was tested using safe, passive methods — no hacking was performed. The findings represent weaknesses visible from outside the website, the same way an attacker would first look at it. **Ten security issues were identified**, including one Critical and three High severity vulnerabilities that require immediate attention.

Security Posture: Critical

The website is missing fundamental security protections that every modern website should have. Several of these issues could allow an attacker to steal visitor information, impersonate the site, or access internal systems — without any hacking skill required.

02 Identified Vulnerabilities

All ten findings are listed below. Each row shows the Finding ID, the technical name, a plain-language summary, and the risk level assigned using the industry-standard CVSS scoring system.

ID	VULNERABILITY	PLAIN ENGLISH SUMMARY	RISK	CVSS
F-01	Open Telnet Port (23)	A back door to the server is wide open with no locks	CRITICAL	9.1
F-02	Missing Content-Security-Policy	The site has no protection against malicious scripts	HIGH	7.4
F-03	Outdated TLS 1.0/1.1	The encryption protecting site visitors is outdated	HIGH	7.5
F-04	Server Version Disclosed	The server is announcing its software version to strangers	HIGH	6.5
F-05	Missing HSTS Header	The site does not force visitors to use a secure connection	MEDIUM	6.1
F-06	Missing X-Frame-Options	The site can be embedded in fake pages to trick visitors	MEDIUM	5.4
F-07	Insecure Session Cookies	Login tokens can be stolen by scripts or sent insecurely	MEDIUM	5.9
F-08	Directory Listing Enabled	Anyone can browse the server's files like a folder on a desktop	MEDIUM	5.3
F-09	Missing Referrer-Policy	The site leaks where visitors came from to other websites	LOW	3.1
F-10	Verbose PHP Error Messages	Error pages reveal internal file paths and code details	LOW	3.5

03 Critical & High Risk Findings

F-01 Open Telnet Port (Port 23) — CVSS 9.1 CRITICAL

WHAT DOES THIS MEAN

Telnet is an old remote-access technology that sends everything — including usernames and passwords — in plain text, having port 23 open is like leaving a door wide open and nailing the door shut. Anyone on the internet can try to connect. There is no encryption whatsoever.

TECHNICAL EVIDENCE

```
nmap scan result:
23/tcp   open   telnet   Linux telnetd

Confirmed active and accepting connections
from external IPs.
```

HOW TO FIX IT

1. **Disable the Telnet service immediately** `sudo systemctl disable telnet --now`
2. Block the port at the firewall `ufw deny 23/tcp`
3. If remote access is needed, use SSH (port 22) instead — it is encrypted and secure.
4. Verify Telnet is closed after fix `nmap -p 23 lynx.net:ru:lp1`

F-02 Missing Content-Security-Policy (CSP) Header — CVSS 7.4 HIGH

WHAT DOES THIS MEAN

A Content Security Policy is like a guest list for your website's scripts. Without it, any script injected into your page — whether through a hacked ad network, a third-party plugin, or a vulnerability — runs freely. This is the primary defence against Cross-Site Scripting (XSS) attacks.

TECHNICAL EVIDENCE

```
curl -I http://testphp.vulnweb.com

HTTP/1.1 200 OK
Server: Apache/2.4.7 (Ubuntu)
Content-Type: text/html
[Content-Security-Policy: ABSENT]
```

HOW TO FIX IT

1. Add this line to your Apache configuration or .htaccess file `Header set Content-Security-Policy "default-src 'self'"`
2. Test on staging first using report-only mode `Content-Security-Policy-Report-Only`
3. Verify with the free tool at **securityheaders.com** — aim for a grade of A or B.

F-03 Outdated TLS Protocol — Version 1.0 & 1.1 Accepted — CVSS 7.5 HIGH

WHAT DOES THIS MEAN

TLS is the technology that encrypts data between your website and visitors (the padlock in the browser). TLS 1.0 and 1.1 are outdated versions with known weaknesses — attackers on the same Wi-Fi network can use these weaknesses to intercept and read what appears to be an encrypted connection.

TECHNICAL EVIDENCE

```
SSL Labs scan result: Overall Grade: C

TLS 1.0: YES (should be NO)
TLS 1.1: YES (should be NO)
TLS 1.2: YES (OK)
Weak ciphers RC4-SHA: offered
```

HOW TO FIX IT

1. In your Apache SSL configuration, replace the SSLProtocol line with `SSLProtocol all -SSLv3 -TLSv1 -TLSv1.1`
2. Remove weak ciphers `SSLCipherSuite HIGH:!aNULL:!MD5:!RC4`
3. Restart Apache `sudo systemctl restart apache2`
4. Re-test on ssllabs.com — target an A rating.

04 Medium & Low Risk Findings

F-04 Server Version Disclosed — CVSS 6.5 HIGH

WHAT DOES THIS MEAN

The server tells every visitor exactly which version of Apache and PHP it is running. This is like putting a sign on your door saying "I use a 2014 deadbolt model." Attackers use this to look up known weaknesses for that exact version. PHP 5.6.40 reached end-of-life in 2018 and has over 20 known unpatched vulnerabilities.

EVIDENCE

```
Server: Apache/2.4.7 (Ubuntu)
X-Powered-By: PHP/5.6.40
```

HOW TO FIX IT

1. Add to Apache config `ServerTokens Prod`
2. Also add `ServerSignature Off`
3. Remove PHP header `Header unset X-Powered-By`
4. **Upgrade PHP** — version 5.6 is 6 years past end-of-life. Minimum PHP 8.2

F-05 Missing HSTS Header — CVSS 6.1 MEDIUM

WHAT DOES THIS MEAN

Without this header, a visitor who types the website address without "https://" might connect insecurely first — giving attackers on the same network an opportunity to intercept that initial connection before the secure one starts. HSTS makes browsers remember to always use the secure version.

EVIDENCE

```
Strict-Transport-Security:
ABSENT [on all responses]
```

HOW TO FIX IT

1. Add to Apache config `Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"`
2. This is a one-line fix with no risk to functionality.

F-06 Missing X-Frame-Options — CVSS 5.4 MEDIUM

WHAT DOES THIS MEAN

Attackers can embed this website invisibly inside their own fake page. Visitors think they're clicking a button on the fake page, but they're actually clicking a button on the real site — potentially confirming transactions or changing account settings.

HOW TO FIX IT

1. One line in Apache config `Header always set X-Frame-Options "DENY"`
2. This prevents the site from being embedded anywhere.

F-07 Insecure Session Cookies — CVSS 5.9 MEDIUM

WHAT DOES THIS MEAN

When a user logs in, the site gives their browser a "session token" — like a wristband at an event. This wristband (cookie) lacks two important protections: it can be read by scripts (should be hidden) and it can be sent over an unencrypted connection (should be secure-only).

EVIDENCE

```
PHPSESSID cookie:
HttpOnly: false ✗
Secure: false ✗
SameSite: not set ✗
```

HOW TO FIX IT

1. In php.ini `session.cookie_httponly = 1`
2. Also `session.cookie_secure = 1`
3. And `session.cookie_samesite = Strict`

F-08 Directory Listing — CVSS 5.3 MEDIUM

WHAT DOES THIS MEAN

Visiting /images/ shows a full list of every file in that folder — like leaving a filing cabinet unlocked with the drawers open.

FIX

1. Apache config `Options -Indexes`

F-09 Missing Referrer-Policy — CVSS 3.1 LOW

WHAT DOES THIS MEAN

When visitors click links away from this site, third-party sites can see the full URL they came from — which may include search terms or page paths.

FIX

1. `Header set Referrer-Policy "strict-origin-when-cross-origin"`

F-10 Verbose Error Pages — CVSS 3.5 LOW

WHAT DOES THIS MEAN

When an error occurs, PHP shows the file path and line number of the code — like a blueprint of the building handed to a burglar.

FIX

1. `php.ini` `display_errors = Off` and `log_errors = On`

05 Prioritized Remediation Plan

All findings are organized into three action tiers. Start with Tier 1 — every item there is a quick, high-impact fix that takes less than a day.

TIER 1 — FIX THIS WEEK (4 ACTIONS)

ID	ACTION REQUIRED	EFFORT	IMPACT
F-01	Close Telnet Port 23 immediately Disable service + block at firewall	1 hour	CRITICAL
F-02	Add Content-Security-Policy header Start with report-only, then enforce	2 hours	HIGH
F-03	Disable TLS 1.0 and TLS 1.1 Update SSLProtocol in Apache config	1 hour	HIGH
F-04	Hide server version + upgrade PHP ServerTokens Prod; upgrade PHP 5.6 → 8.2	4 hours	HIGH

TIER 2 — FIX THIS MONTH (4 ACTIONS)

ID	ACTION	EFFORT	IMPACT
F-05	Enable HSTS header max-age=31536000; includeSubDomains	15 min	MEDIUM
F-06	Add X-Frame-Options: DENY One Apache config line	15 min	MEDIUM
F-07	Set HttpOnly + Secure flags on cookies Update php.ini session settings	30 min	MEDIUM
F-08	Disable directory listing Options -Indexes in Apache config	15 min	MEDIUM

TIER 3 — NEXT MAINTENANCE WINDOW (2 ACTIONS)

ID	ACTION	EFFORT	IMPACT
F-09	Add Referrer-Policy header strict-origin-when-cross-origin	15 min	LOW
F-10	Disable PHP error display display_errors=Off in php.ini	15 min	LOW

After Fixing Tier 1

Re-run securityheaders.com — expect to improve from grade F to C or higher within 30 minutes of Tier 1 fixes.

Verification

After all fixes, re-scan using the same tools to confirm each issue is resolved. Document the before/after grades for your portfolio.

Report Disclaimer: This assessment was produced as part of a supervised cybersecurity learning exercise using passive, read-only methods only. The target site (testphp.vulnweb.com) is an intentionally vulnerable demo site maintained by Acunetix for security education. No systems were exploited, no data was accessed, and no harmful activity was performed. This document is for educational and portfolio use only.